Unit 5: Applying Cybersecurity Frameworks Across Different Industries

Section 1: Understanding Cybersecurity Frameworks

Q1. What is the difference between a cybersecurity framework and a standard?

A framework is used to guide how to address security risks, and a standard describes requirements or best-practice controls. Both can assist organisations to enhance their security and manage risk effectively.

Q2. Why do organisations need different security frameworks?

Risk profiles vary across organisations. Banks protect financial transactions; hospitals protect patient information and clinical services; food factories protect production systems. Therefore, frameworks must take into account the specific risk profile of the organisation **(Kirvan, 2025).**

Q3. Does compliance guarantee complete security?

However, compliance isn't a silver bullet for all cyber threats. Organisations must still actively test their controls and find weaknesses and bugs in their systems.

2. Recommended frameworks and security tests

International Bank

Recommended frameworks: ISO/IEC 27001, NIST Cybersecurity Framework and PCI DSS.

Because banks process sensitive financial information and are subject to threats such as fraud, phishing, and ransomware, recommended frameworks include ISO/IEC 27001, which is a standard for information security management; NIST, which offers guidance for managing cybersecurity risks; and PCI DSS, which pertains to environments handling payment-card data.

Recommended tests and actions:Activity-Security

- Perform vulnerability assessments and penetration testing.
- Test multi-factor authentication and privileged account access.
- Evaluate encryption and payment-system security.
- Conduct phishing simulations and incident-response exercises.
- Test backup restoration and disaster recovery procedures.

Management should review supplier risks and ensure that security controls meet the requirements of financial and data protection standards.

2. Large Hospital Recommended framework:

ISO/IEC 27001, NIST Cybersecurity Framework and other healthcare-related security requirements. Hospitals hold sensitive data about patients

and require the availability of clinical services. An attack could lead to the exposure of patient records or a disruption to critical care.

Recommended tests and activities:

- Test the security of patient record systems and hospital networks.
- Assess staff access rights and controls.
- Test backup and restoration processes.
- Carry out a ransomware attack simulation and awareness training for staff.
- Assess the security of medical devices and network segmentation.

Management should ensure the confidentiality of patient records, the availability of clinical services and compliance with relevant data-protection laws.

3. Large food manufacturing factory

Applicable standards: ISO/IEC 27001, NIST Cybersecurity Framework, and IEC 62443 for Industrial Control Systems.

A large food manufacturing facility depends on automated equipment, production lines and monitoring systems. A cyberattack could result in the

disruption of production, the alteration of production settings, or the manipulation of product traceability.

Recommended activities and testing:

- Test industrial control system vulnerabilities.
- Test network isolation of office and production areas.
- Review remote access of contractors and suppliers.
- Test disaster recovery planning to restore backups and restart production.
- Alert on unauthorised changes to production systems.

Testing needs to be tightly controlled to ensure that no damage or safety issues arise. Management should incorporate cybersecurity risk into their overall operational risk management program and food safety program.

Conclusion:

It is important that cybersecurity frameworks consider organisations' risks and requirements. Financial institutions will be concerned with their financial transactions and payments, while healthcare institutions will want to ensure the safety of patients' data and medical services; food processing

plants, however, will prioritise industrial cybersecurity. As Adhillah et al. (2025) suggest, the connection between ERM and overall enterprise risk should be considered. By conducting regular security assessments, providing staff education, and making ongoing improvements, organisations can enhance their defences.

Reference:

- Adhillah, M.N. *et al*. (2025) 'Systematic Literature Review the Development of Enterprise Risk Management', *Jurnal Manajemen Bisnis, Akuntansi dan Keuangan*, 4(1), pp. 81–100.

- Kirvan, P. (2021) *Top 15 IT security frameworks and standards explained*.